ĐẠI HỌC QUỐC GIA THÀNH PHỐ HỒ CHÍ MINH

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ THÔNG TIN

LOGO UIT

Đại học Công nghệ Thông tin
ĐHQG-HCM

BÁO CÁO ĐỒ ÁN CUỐI KỲ

LẬP TRÌNH KỊCH BẢN TỰ ĐỘNG HÓA CHO QUẢN TRỊ VÀ BẢO MẬT MẠNG

Mã lớp: NT542.R11

TÊN ĐỀ TÀI

Xây dựng hệ thống tự động đánh giá và khắc phục cấu hình bảo mật tường lửa Palo Alto dựa trên tiêu chuẩn CIS Benchmark

Giảng viên hướng dẫn: ThS. Trần Thị Dung, ThS. Văn Thiên Luân

Sinh viên thực hiện: Huỳnh Minh Hiếu – 23520477

Nguyễn Phát Đạt – 23520258

TP. Hồ Chí Minh, năm 2026

Lời cảm ơn

Nhóm sinh viên thực hiện đề tài xin gửi lời cảm ơn chân thành và sâu sắc nhất đến quý Thầy Cô Bộ môn Mạng máy tính và Truyền thông, Khoa Mạng máy tính và Truyền thông, Trường Đại học Công nghệ Thông tin, Đại học Quốc gia Thành phố Hồ Chí Minh, đã truyền đạt nền tảng kiến thức chuyên môn vững chắc và tạo điều kiện học tập thuận lợi nhất cho sinh viên.

Đặc biệt, nhóm xin bày tỏ lòng biết ơn sâu sắc đến ThS. Trần Thị Dung và ThS. Văn Thiên Luân, hai giảng viên trực tiếp hướng dẫn môn học Lập trình kịch bản tự động hóa cho quản trị và bảo mật mạng (NT542.R11). Sự định hướng tận tình, những gợi ý kỹ thuật thực tế và các nhận xét sâu sát của quý Thầy Cô trong từng giai đoạn báo cáo đã giúp nhóm từng bước vượt qua các khó khăn kỹ thuật để hoàn thiện đồ án này một cách trọn vẹn.

Thành phố Hồ Chí Minh, năm 2026

Nhóm sinh viên thực hiện

Huỳnh Minh Hiếu – Nguyễn Phát Đạt

Lời cam đoan

Nhóm sinh viên xin cam đoan rằng đồ án này là công trình nghiên cứu và thực nghiệm độc lập của nhóm dưới sự hướng dẫn chuyên môn của các giảng viên phụ trách môn học.

Toàn bộ các thông số kỹ thuật, cấu hình, dữ liệu kiểm tra và hình ảnh minh chứng thực nghiệm trong báo cáo đều được thu thập thực tế từ môi trường lab triển khai trên hạ tầng CMC Cloud. Nhóm tự nghiên cứu và phát triển toàn bộ mã nguồn kiểm tra tự động Python và kịch bản điều phối Ansible, không sao chép từ bất kỳ công trình nào khác mà không có trích dẫn nguồn gốc rõ ràng.

Đại diện nhóm sinh viên
Huỳnh Minh Hiếu

Danh mục từ viết tắt

Từ viết tắt	Thuật ngữ tiếng Anh	Ý nghĩa tiếng Việt
API	Application Programming Interface	Giao diện lập trình ứng dụng
CIS	Center for Internet Security	Trung tâm an ninh Internet Hoa Kỳ
CLI	Command Line Interface	Giao diện dòng lệnh điều khiển
GUI	Graphical User Interface	Giao diện đồ họa người dùng
HA	High Availability	Tính sẵn sàng cao, cơ chế dự phòng
HTTPS	Hypertext Transfer Protocol Secure	Giao thức truyền tải siêu văn bản bảo mật
NGFW	Next-Generation Firewall	Tường lửa thế hệ mới
NTP	Network Time Protocol	Giao thức đồng bộ thời gian mạng
PAN-OS	Palo Alto Networks Operating System	Hệ điều hành tường lửa Palo Alto
REST	Representational State Transfer	Kiểu kiến trúc dịch vụ web REST
SNMP	Simple Network Management Protocol	Giao thức quản trị mạng đơn giản
SSH	Secure Shell	Giao thức phiên làm việc từ xa an toàn
TLS	Transport Layer Security	Giao thức bảo mật tầng truyền vận
XML	Extensible Markup Language	Ngôn ngữ đánh dấu mở rộng
XPath	XML Path Language	Ngôn ngữ truy vấn thành phần tài liệu XML

MỤC LỤC

Lời cảm ơn ..... **i**

Lời cam đoan ..... **ii**

Danh mục từ viết tắt ..... **iii**

Danh mục bảng ..... **vi**

Danh mục hình ảnh ..... **vii**

Danh mục mã nguồn ..... **viii**

CHƯƠNG 1 Giới thiệu về đề tài và Chuẩn CIS Benchmark **1**

1.1 Tóm tắt **1**

1.2 Nội dung **3**

CHƯƠNG 2 Phương pháp **9**

2.1 Phương pháp Đánh giá Thủ công (Manual) **9**

2.1.1 Môi trường và Công cụ thực hiện 9

2.1.2 Quy trình thực hiện rà soát thủ công 9

2.2 Phương pháp Đánh giá Tự động (Automation) **10**

2.2.1 Công cụ cốt lõi và Công nghệ sử dụng 10

2.2.2 Cấu trúc module hóa của phần mềm 10

2.2.3 Hai cơ chế thu thập dữ liệu chuyên sâu 11

2.2.4 Phân biệt Local Automation và Remote Automation 11

CHƯƠNG 3 Triển khai **12**

3.1 Mô hình triển khai **12**

3.2 Triển khai Manual **13**

3.2.1 1. Thiết lập và Quản trị Thiết bị 13

3.2.2 2. Chính sách Mật khẩu (Password Profiles) 17

3.2.3 3. Dịch vụ Hệ thống và Ghi log 18

3.2.4 4. Độ sẵn sàng cao (High Availability) 20

3.2.5 5. Lọc bảo vệ vùng mạng (Zone Protection) 21

3.2.6 6. Chính sách Bảo mật (Security Policies) 22

3.2.7 Phụ lục Bảng tổng kết Checklist kết quả Manual 23

3.3 Triển khai Automation **25**

3.3.1 Chuẩn bị môi trường và Cấu trúc dự án 25

3.3.2 Thiết lập Inventory và Quản lý bí mật an toàn 26

3.3.3 Quy trình Audit tự động 26

3.3.4 Quy trình Remediation và Cơ chế Rollback an toàn 26
CHƯƠNG 4 Kết quả 27
4.1 Kết quả thực nghiệm Local và Remote Automation 27
4.2 Đánh giá và So sánh Hiệu năng giữa Manual và Automation . . . 27
CHƯƠNG 5 Kết luận và Hướng phát triển 28
5.1 Kết luận 28
5.2 Hạn chế của đề tài 29
5.3 Hướng phát triển trong tương lai 29
Tài liệu tham khảo 30

DANH MỤC BẢNG

2 Các nhóm nội dung CIS Benchmark được nhóm lựa chọn triển khai 2
3 Danh mục chi tiết 30 khuyến nghị CIS Benchmark được nhóm lựa chọn triển khai 3
4 Bảng phân bổ địa chỉ IP và vai trò thiết bị trong lab CMC Cloud 13
5 Bảng tổng kết checklist kết quả rà soát thủ công trên cụm tường lửa 23
6 Bảng so sánh định lượng hiệu năng giữa phương pháp Manual và Automation 28

DANH MỤC HÌNH ẢNH

1 Sơ đồ topo kiến trúc mạng lab CMC Cloud triển khai thực nghiệm 12
2 Cấu hình Login Banner trên tường lửa Palo Alto 14
3 Kích hoạt tính năng Log on High DP Load 14
4 Cấu hình danh sách Permitted IP Addresses trên cổng Management 14
5 Tắt dịch vụ HTTP và Telnet trên cổng Management 15
6 Kiểm tra các Interface Management Profiles 15
7 Thiết lập thời gian ngắt phiên rảnh rỗi Idle Timeout 16
8 Cấu hình giới hạn số lần đăng nhập thất bại 16
9 Cấu hình thời gian khóa tài khoản Lockout Time 16
10 Cấu hình bảo mật giao thức SNMP 17
11 Bật tính năng Minimum Password Complexity 17
12 Cấu hình chi tiết các tham số độ phức tạp mật khẩu 18
13 Kiểm tra danh mục Password Profiles 18
14 Kích hoạt xác thực máy chủ cập nhật Verify Update Server Identity 19
15 Cấu hình máy chủ đồng bộ thời gian NTP 19
16 Tạo cấu hình hồ sơ máy chủ Syslog Server Profile 19
17 Kiểm tra trạng thái đồng bộ cụm High Availability 20
18 Cấu hình giám sát liên kết Link and Path Monitoring 20
19 Cấu hình Passive Link State và Election Settings 21
20 Cấu hình chống tấn công SYN Flood bằng SYN Cookies 21
21 Kích hoạt cơ chế hủy gói tin giả mạo IP và TCP bất thường 22
22 Rà soát các luật an ninh chiều từ vùng mạng Untrust 22
23 Đặt luật chặn IP độc hại lên vị trí trên cùng của danh sách 22
24 Bật ghi log ở cuối phiên cho các luật mặc định 23
25 Kết quả quét tự động hóa toàn bộ 30 CIS Controls đạt tỷ lệ tuân thủ 100% . 27

DANH MỤC MÃ NGUỒN

1 Cấu trúc cây thư mục mã nguồn hệ thống tự động hóa 25

1 Giới thiệu về đề tài và Chuẩn CIS Benchmark

1.1 Tóm tắt

Trong các hệ thống mạng doanh nghiệp hiện nay, tường lửa thế hệ mới (Next-Generation Firewall – NGFW) của Palo Alto luôn là chốt chặn quan trọng nhất để phân chia vùng mạng, kiểm soát luồng dữ liệu và ngăn chặn các cuộc tấn công. Tuy nhiên, dù thiết bị có hiện đại đến đâu và mua đủ license đắt tiền, hệ thống vẫn có thể gặp rủi ro lớn nếu người quản trị cấu hình không đúng cách. Thực tế cho thấy rất nhiều sự cố an ninh bắt nguồn từ các sơ hở rất cơ bản, chẳng hạn như mở port quản trị ra ngoài Internet, dùng giao thức không mã hóa như HTTP hay Telnet, đặt mật khẩu đơn giản, không giới hạn thời gian tự ngắt phiên đăng nhập hoặc bỏ qua các thiết lập dự phòng đường truyền.

Để có một bộ quy chuẩn rõ ràng nhằm rà soát và siết chặt bảo mật, nhóm chọn sử dụng tài liệu CIS Palo Alto Firewall 11 Benchmark phiên bản v1.2.0 áp dụng cho hệ điều hành PAN-OS 11.x. Tài liệu này đưa ra các khuyến nghị rất chi tiết từ mức cơ bản đến nâng cao (Profile Level 1 và Level 2), giải thích rõ tại sao cần làm, các bước kiểm tra (Audit) và cách thức khắc phục (Remediation) khi cấu hình bị vi phạm.

Trong đồ án này, nhóm tập trung giải quyết bài toán kiểm tra và làm cứng cấu hình tường lửa bằng cách kết hợp song song cả hai phương pháp:

- **Đánh giá thủ công (Manual):** Nhóm trực tiếp đăng nhập vào giao diện Web GUI hoặc gõ lệnh trong CLI (Console/SSH) để rà soát từng mục theo khuyến nghị của CIS. Cách làm này giúp nhóm hiểu sâu từng tính năng của hệ điều hành PAN-OS và có được số liệu thực tế làm căn cứ đối chứng.
- **Đánh giá và khắc phục tự động (Automated):** Nhóm viết chương trình bằng Python để giao tiếp với tường lửa thông qua PAN-OS XML API trên nền kết nối bảo mật HTTPS cổng 443. Đồng thời, nhóm tích hợp thêm Ansible để điều phối, cho phép quét kiểm tra và tự động cấu hình hàng loạt trên nhiều thiết bị (Fleet Management) một cách đồng bộ và nhanh chóng.

Toàn bộ mô hình thực nghiệm được nhóm triển khai trên hạ tầng CMC Cloud, gồm một cặp tường lửa Palo Alto VM-Series chạy PAN-OS 11.2.5 cấu hình High Availability chế độ Active/Passive, một máy Linux Bastion dùng làm máy trạm chạy kịch bản Python và Ansible, cùng một máy Windows Bastion dùng để thao tác giao diện quản trị đồ họa.

Kho mã nguồn của đề tài: `github.com/mhieudzvcl/CIS-Benchmark-PaloAlto`.

Bảng 2 tóm tắt 6 nhóm nội dung với 30 khuyến nghị CIS được nhóm lựa chọn triển khai trong đồ án.

Bảng 2: Các nhóm nội dung CIS Benchmark được nhóm lựa chọn triển khai

STT	Nhóm nội dung	Số lượng	Hạng mục và Ý nghĩa kỹ thuật triển khai
1	Quản trị thiết bị (Device Setup & Mgmt)	9 controls	Cấu hình banner cảnh báo đăng nhập, bật log cảnh báo khi tải Data Plane cao, giới hạn IP được phép quản trị, tắt HTTP và Telnet, đặt thời gian tự ngắt phiên rảnh rỗi và khóa tài khoản khi gõ sai mật khẩu nhiều lần.
2	Chính sách mật khẩu (Password Profiles)	10 controls	Bật yêu cầu độ phức tạp mật khẩu, quy định độ dài tối thiểu, số lượng chữ hoa, chữ thường, chữ số, ký tự đặc biệt, thời hạn đổi mật khẩu, lưu lịch sử mật khẩu cũ và không để tồn tại các profile ghi đè chính sách chung.
3	Dịch vụ hệ thống và Ghi log (Services & Logging)	3 controls	Bật xác thực máy chủ cập nhật chính hãng, cấu hình máy chủ NTP đồng bộ thời gian chính và phụ, cấu hình chuyển tiếp log tập trung về Syslog Server.
4	Độ sẵn sàng cao (High Availability – HA)	3 controls	Kiểm tra trạng thái đồng bộ giữa hai firewall Active và Passive, bật cơ chế giám sát đường truyền (Path Monitoring), để cổng Passive ở chế độ Auto và tắt tính năng giành quyền (Preemption).
5	Lọc bảo vệ vùng mạng (Zone Protection)	2 controls	Cấu hình Zone Protection Profile để chống tấn công SYN Flood bằng kỹ thuật SYN Cookies, tự động loại bỏ các gói tin giả mạo IP Spoofing và các gói tin TCP bất thường.
6	Chính sách bảo mật (Security Policies)	3 controls	Kiểm tra không cho phép mở cổng ANY từ vùng Untrust, đặt luật chặn các IP độc hại lên đầu danh sách chính sách và bật ghi log ở cuối phiên cho các luật mặc định.

1.2 Nội dung

Tài liệu CIS Palo Alto Firewall 11 Benchmark v1.2.0 được xây dựng dựa trên sự đồng thuận của cộng đồng chuyên gia an ninh mạng quốc tế. Cấu trúc tài liệu bao gồm các quy định pháp lý (Terms of Use), định nghĩa cấp độ bảo vệ (Profile Level 1 và Level 2), các khuyến nghị kỹ thuật chi tiết và phần phụ lục đối sánh.

Mỗi khuyến nghị trong tài liệu được chuẩn hóa thành các mục thông tin rõ ràng:

- **Tiêu đề và Mã số (Title & Identifier):** Định danh vị trí của khuyến nghị trong cây phân cấp bảo mật.
- **Trạng thái đánh giá (Assessment Status):** Phân loại thành *Automated* (có thể tự động hóa đánh giá logic qua máy tính) hoặc *Manual* (yêu cầu con người thẩm định theo bối cảnh mạng).
- **Cấp độ bảo vệ (Profile Applicability):** Level 1 dành cho bảo mật cơ bản với độ ảnh hưởng dịch vụ thấp, Level 2 dành cho môi trường yêu cầu an toàn cao và chiều sâu phòng thủ.
- **Mô tả và Cơ sở an ninh (Description & Rationale):** Giải thích lý do tại sao cấu hình này là cần thiết và mối đe dọa tương ứng.
- **Quy trình kiểm tra và Khắc phục (Audit & Remediation):** Chỉ rõ các bước xác minh trên giao diện Web GUI hoặc dòng lệnh CLI, cùng các bước thay đổi để đưa hệ thống về trạng thái an toàn.

Bảng 3 trình bày chi tiết toàn bộ 30 khuyến nghị cấu hình được nhóm lựa chọn triển khai trong đồ án, bao gồm mã số, tiêu đề, trạng thái đánh giá, cấp độ bảo vệ, nội dung yêu cầu và lý do bảo mật tương ứng.

Bảng 3: Danh mục chi tiết 30 khuyến nghị CIS Benchmark được nhóm lựa chọn triển khai

Mục	Khuyến nghị	Trạng thái	Cấp độ	Nội dung cấu hình	Lý do bảo mật
1. Thiết lập và Quản trị Thiết bị (Device Setup and Administration)					
1.1.2	Legal Notice Login Banner	Automated	Level 1	Cấu hình biểu ngữ cảnh báo pháp lý khi đăng nhập hệ thống, thông báo rõ việc ghi log và không dùng từ chào mừng.	Loại bỏ khả năng người dùng biện minh là truy cập nhầm, tạo cơ sở pháp lý xử lý khi có xâm nhập trái phép.
Còn tiếp ở trang sau					

Bảng 3 (tiếp theo)

Mục	Khuyến nghị	Trạng thái	Cấp độ	Nội dung cấu hình	Lý do bảo mật
1.1.3	Log on High DP Load	Automated	Level 1	Bật tính năng tự động ghi log khi tải CPU của Data Plane vượt ngưỡng cao.	Giúp quản trị viên phát hiện kịp thời các đợt tấn công từ chối dịch vụ hoặc bất thường lưu lượng mạng.
1.2.1	Permitted IP Mgmt Interface	Manual	Level 1	Chỉ cho phép các địa chỉ IP hoặc dải mạng quản trị tin cậy kết nối đến cổng Management.	Ngăn ngừa việc kẻ tấn công từ Internet hoặc các vùng mạng nội bộ khác quét dò và tấn công cổng quản trị.
1.2.3	Disable HTTP/Telnet Mgmt	Automated	Level 1	Tắt hoàn toàn dịch vụ quản trị HTTP và Telnet trên cổng Management.	Ngăn chặn việc truyền mật khẩu và phiên làm việc dưới dạng văn bản rõ không mã hóa qua mạng.
1.2.4	Disable HTTP/Telnet Profiles	Automated	Level 1	Rà soát tất cả Interface Management Profiles, bảo đảm không cho phép HTTP và Telnet.	Đảm bảo các cổng giao tiếp dữ liệu nội bộ không vô tình mở các dịch vụ quản trị thiếu an toàn.
1.4.1	Management Idle Timeout	Automated	Level 1	Thiết lập thời gian tự động ngắt phiên rảnh rỗi không vượt quá 10 phút.	Giảm thiểu rủi ro bị chiếm quyền điều khiển phiên làm việc khi quản trị viên rời khỏi máy trạm.

Còn tiếp ở trang sau

Bảng 3 (tiếp theo)

Mục	Khuyến nghị	Trạng thái	Cấp độ	Nội dung cấu hình	Lý do bảo mật
1.4.2	Failed Attempts Lockout	Automated	Level 1	Thiết lập khóa tài khoản sau không quá 5 lần đăng nhập thất bại liên tiếp.	Ngăn chặn hiệu quả các cuộc tấn công dò đoán mật khẩu tự động và tấn công vét cạn (brute-force).
1.4.3	Failed Attempts Lockout Time	Automated	Level 1	Đặt thời gian khóa tài khoản sau khi vượt ngưỡng thất bại tối thiểu 15 phút.	Làm chậm tốc độ dò mật khẩu của kẻ tấn công và tạo thời gian cho quản trị viên phát hiện sự cố.
1.5.1	SNMPv3 or SNMP Disabled	Automated	Level 1	Tắt dịch vụ SNMP hoặc chỉ sử dụng SNMPv3 có mã hóa và xác thực.	SNMPv1 và v2 truyền thông tin dạng rõ, dễ bị nghe lén để thu thập cấu trúc mạng và thông số hệ thống.
2. Chính sách Mật khẩu (Password Profiles)					
1.3.1	Password Complexity Enabled	Automated	Level 1	Bật cơ chế kiểm tra độ phức tạp của mật khẩu quản trị cục bộ.	Đảm bảo tất cả mật khẩu tạo mới hoặc thay đổi đều phải tuân thủ các quy tắc an toàn đã đề ra.
1.3.2	Password Minimum Length	Automated	Level 1	Đặt độ dài mật khẩu tối thiểu từ 12 ký tự trở lên.	Tăng không gian khóa, nâng cao độ khó trước các cuộc tấn công từ điển và bảng băm cầu vồng.
1.3.3	Uppercase Letters ≥ 1	Automated	Level 1	Bắt buộc mật khẩu phải chứa ít nhất 1 ký tự chữ hoa.	Tăng tính ngẫu nhiên và độ phức tạp của chuỗi ký tự mật khẩu.

Còn tiếp ở trang sau

Bảng 3 (tiếp theo)

Mục	Khuyến nghị	Trạng thái	Cấp độ	Nội dung cấu hình	Lý do bảo mật
1.3.4	Lowercase Letters ≥ 1	Automated	Level 1	Bắt buộc mật khẩu phải chứa ít nhất 1 ký tự chữ thường.	Phối hợp cùng ký tự chữ hoa để mở rộng tập ký tự cần dò đoán.
1.3.5	Numeric Digits ≥ 1	Automated	Level 1	Bắt buộc mật khẩu phải chứa ít nhất 1 ký tự chữ số.	Ngăn chặn người dùng đặt mật khẩu chỉ gồm các từ ngữ tự nhiên trong từ điển.
1.3.6	Special Characters ≥ 1	Automated	Level 1	Bắt buộc mật khẩu phải chứa ít nhất 1 ký tự đặc biệt (@, #, $,...).	Tăng tối đa độ phức tạp (entropy) của mật khẩu trước các công cụ bẻ khóa tự động.
1.3.7	Password Change Period	Automated	Level 1	Quy định chu kỳ bắt buộc đổi mật khẩu định kỳ không vượt quá 90 ngày.	Giới hạn khoảng thời gian khai thác nếu mật khẩu vô tình bị lộ lọt ra bên ngoài.
1.3.8	New Password Differs	Automated	Level 1	Yêu cầu mật khẩu mới phải khác mật khẩu cũ ít nhất 3 ký tự.	Tránh tình trạng người dùng chỉ thay đổi một ký tự cuối để đối phó với quy định đổi mật khẩu.
1.3.9	Password History Count	Automated	Level 1	Hệ thống ghi nhớ ít nhất 24 mật khẩu đã sử dụng gần nhất.	Ngăn chặn việc người dùng lập tức đổi lại mật khẩu cũ ngay sau khi bị bắt buộc thay đổi.
1.3.10	No Custom Password Profiles	Automated	Level 1	Đảm bảo không có các Password Profile riêng lẻ tạo ra nhằm ghi đè chính sách chung.	Giữ tính đồng nhất của chính sách mật khẩu, tránh việc tạo ra các tài khoản ngoại lệ yếu kém.
3. Dịch vụ Hệ thống và Ghi log (Services and Logging)					

Còn tiếp ở trang sau

Bảng 3 (tiếp theo)

Mục	Khuyến nghị	Trạng thái	Cấp độ	Nội dung cấu hình	Lý do bảo mật
1.6.1	Verify Update Server Identity	Automated	Level 1	Bật tùy chọn kiểm tra danh tính và chứng chỉ của máy chủ cập nhật chính hãng.	Ngăn ngừa tấn công giả mạo máy chủ cập nhật (Man-in-the-middle) để cài mã độc vào firewall.
1.6.2	NTP Primary and Secondary	Automated	Level 1	Cấu hình máy chủ đồng bộ thời gian NTP chính và phụ đáng tin cậy.	Đảm bảo tính chính xác và đồng bộ của nhãn thời gian (timestamp) trong toàn bộ nhật ký hệ thống.
1.7.1	Syslog Server Profile	Automated	Level 1	Cấu hình hồ sơ chuyển tiếp nhật ký ra máy chủ Syslog tập trung bên ngoài.	Đảm bảo lưu trữ nhật ký an toàn, phục vụ công tác điều tra số và tránh nguy cơ bị xóa log khi máy bị xâm nhập.
4. Độ sẵn sàng cao (High Availability)					
3.1	HA Peer Synchronization	Automated	Level 2	Hai thiết bị tường lửa trong cụm HA phải ở trạng thái kết nối và đồng bộ cấu hình hoàn tất.	Đảm bảo hệ thống có khả năng chuyển đổi dự phòng tức thời khi một node gặp sự cố phần cứng.
3.2	HA Link/Path Monitoring	Automated	Level 2	Cấu hình cơ chế giám sát các liên kết vật lý hoặc đường truyền mạng quan trọng.	Tự động kích hoạt chuyển đổi dự phòng nếu đường truyền kết nối mạng chính bị đứt gãy.

Còn tiếp ở trang sau

Bảng 3 (tiếp theo)

Mục	Khuyến nghị	Trạng thái	Cấp độ	Nội dung cấu hình	Lý do bảo mật
3.3	HA Passive Link Auto	Automated	Level 2	Cổng mạng ở node Passive đặt ở trạng thái Auto và tính năng Preemption được tắt.	Tránh hiện tượng tranh chấp quyền điều khiển (flapping) gây gián đoạn phiên khi node chính phục hồi.
5. Lọc bảo vệ vùng mạng (Zone Protection)					
6.15	SYN Flood Protection Cookies	Automated	Level 1	Áp dụng cơ chế SYN Cookies chống tấn công SYN Flood trong Zone Protection Profile.	Bảo vệ bảng trạng thái kết nối của tường lửa không bị tràn ngập trước các đợt tấn công từ chối dịch vụ TCP.
6.18	Drop Spoofed IP & Bad TCP	Automated	Level 1	Cấu hình tự động hủy bỏ các gói tin giả mạo IP nguồn và các gói tin phân mảnh TCP dị thường.	Ngăn chặn các kỹ thuật thâm nhập mạng qua giả mạo địa chỉ IP và các đợt quét cổng bất thường.
6. Chính sách Bảo mật (Security Policies)					
7.2	No ANY Service Untrust Rule	Automated	Level 1	Không cho phép các luật an ninh mở dịch vụ ANY từ vùng mạng Untrust đi vào.	Thu hẹp bề mặt tấn công, chỉ mở đúng các cổng dịch vụ thực sự cần thiết cho hoạt động kinh doanh.
7.3	Top Rule Blocking Threats	Manual	Level 1	Đặt các quy tắc chặn địa chỉ IP độc hại đã nhận diện ở vị trí ưu tiên cao nhất của Rulebase.	Đảm bảo lưu lượng từ các nguồn nguy hiểm bị triệt tiêu ngay lập tức trước khi được xét duyệt bởi các luật khác.

Còn tiếp ở trang sau

Bảng 3 (tiếp theo)

Mục	Khuyến nghị	Trạng thái	Cấp độ	Nội dung cấu hình	Lý do bảo mật
7.4	Default Rules Logging	Automated	Level 1	Bật tính năng ghi nhật ký ở cuối phiên (Log at Session End) cho các luật ngầm định mặc định.	Ghi lại toàn bộ các nỗ lực truy cập bị từ chối mặc định, phục vụ phân tích lưu lượng bất thường.

2 Phương pháp

2.1 Phương pháp Đánh giá Thủ công (Manual)

2.1.1 Môi trường và Công cụ thực hiện

Đánh giá thủ công là phương pháp kiểm tra nền tảng giúp người thực hiện hiểu sâu cấu trúc từng bảng cấu hình trong hệ điều hành PAN-OS 11.2.5. Các công cụ sử dụng gồm:

- **Máy trạm Windows Bastion (10.0.10.21):** Sử dụng trình duyệt Google Chrome kết nối HTTPS đến cổng quản trị của PA-CIS-01 (`https://10.0.10.11`) và PA-CIS-02 (`https://10.0.10.12`).
- **Phiên dòng lệnh CLI qua SSH:** Kết nối từ máy trạm quản trị vào tường lửa bằng tài khoản `admin` để thực hiện các câu lệnh kiểm tra cấu hình dạng `show config running` hoặc lệnh truy vấn trạng thái thời gian thực `show high-availability state`.

2.1.2 Quy trình thực hiện rà soát thủ công

Quy trình thực hiện gồm 4 bước kỹ thuật tuần tự:

1. **Truy cập hệ thống:** Mở trình duyệt đăng nhập vào Web GUI của tường lửa hoặc mở terminal SSH.
2. **Định vị tham số:** Căn cứ vào mô tả kỹ thuật của khuyến nghị, điều hướng đến đúng tab hoặc gõ đúng lệnh truy vấn trên thiết bị.
3. **Đối chiếu giá trị:** So sánh thông số thực tế đang hiển thị với tiêu chuẩn CIS Benchmark. Nếu đạt chuẩn ghi nhận `PASS`, nếu sai lệch ghi nhận `FAIL`.
4. **Lưu vết minh chứng:** Chụp ảnh màn hình hiển thị rõ ràng đường dẫn menu, tên tường lửa và giá trị thông số để làm bằng chứng đối chứng độc lập.

2.2 Phương pháp Đánh giá Tự động (Automation)

2.2.1 Công cụ cốt lõi và Công nghệ sử dụng

Nhóm khẳng định rõ: *Trên máy chủ Linux Bastion, hệ thống đánh giá tự động tuyệt đối KHÔNG sử dụng SSH để can thiệp cấu hình hoặc phân tích văn bản (CLI scraping).* Thay vào đó, nhóm chuẩn hóa toàn bộ việc tương tác thông qua **PAN-OS XML API trên nền kết nối bảo mật HTTPS cổng 443**.

Các lý do kỹ thuật nhóm không sử dụng SSH:

- Kết quả dòng lệnh CLI trả về là văn bản thuần không có cấu trúc cố định, chứa các mã điều khiển định dạng terminal và phụ thuộc vào phiên bản hiển thị, khiến bộ phân tích dễ bị lỗi khi cập nhật firmware.
- Chi phí mở phiên SSH và xử lý luồng văn bản rất tốn tài nguyên CPU, không đáp ứng được yêu cầu quét nhanh trên quy mô nhiều thiết bị.
- Giao tiếp qua PAN-OS XML API cho phép nhận dữ liệu XML có cấu trúc cây rõ ràng, dễ dàng dùng XPath truy vấn chính xác từng trường thông số mà không bao giờ bị nhầm lẫn.

Hệ thống sử dụng các công nghệ nòng cốt sau:

- **Ngôn ngữ lập trình:** Python 3.12 với các thư viện:
  - `requests`: Gửi gói tin HTTPS POST/GET đến API Controller và xử lý mã phản hồi.
  - `lxml`: Phân tích cú pháp cây XML hiệu năng cao, trích xuất dữ liệu bằng XPath.
  - `PyYAML`: Đọc các quy tắc kiểm tra định nghĩa trong tệp tin `rules/cis_controls.yaml`.
  - `Jinja2`: Kết xuất báo cáo HTML Dashboard trực quan từ dữ liệu kiểm toán.
- **Framework điều phối:** Ansible Core, cho phép quản lý tập trung và thực thi tự động đồng thời trên toàn bộ các firewall trong hệ thống theo mô hình không cần agent (Agentless).

2.2.2 Cấu trúc module hóa của phần mềm

Mã nguồn được tổ chức thành các tầng chức năng độc lập nhằm bảo đảm tính bảo mật và khả năng mở rộng:

- **Tầng kết nối (Client Layer – `src/panos_client.py`):** Chịu trách nhiệm khởi tạo kết nối HTTPS an toàn, quản lý API Key, gửi yêu cầu trích xuất cấu hình và xử lý các lỗi mạng.
- **Tầng logic kiểm tra (Logic Layer – `src/cis_scanner.py`):** Nạp các biểu

thức XPath và đối chiếu các giá trị cấu hình với ngưỡng an toàn được quy định trong CIS Benchmark.

- **Tầng khắc phục (Remediation Layer – `src/remediation.py`):** Tạo các payload XML chuẩn để sửa các lỗi cấu hình vi phạm, hỗ trợ cả chế độ có phê duyệt xác nhận và chế độ tự động hoàn toàn.
- **Tầng báo cáo (Reporting Layer – `src/report_generator.py`):** Xuất kết quả kiểm toán ra tệp tin JSON và giao diện web HTML.

2.2.3 Hai cơ chế thu thập dữ liệu chuyên sâu

Hệ thống triển khai hai cơ chế thu thập dữ liệu tách biệt để đảm bảo tính toàn diện:

1. **Thu thập Running Configuration (`type=config&action=show`):** Lấy toàn bộ cây dữ liệu XML cấu hình tĩnh đang có hiệu lực hoạt động trên hệ thống (đã được Commit thành công). Nguồn dữ liệu này dùng để kiểm tra 27/30 tiêu chí về chính sách bảo vệ, thông số mật khẩu, dịch vụ mạng và quy tắc tường lửa.
2. **Thu thập Trạng thái Vận hành Thời gian thực (`type=op&cmd=...`):** Sử dụng các lệnh vận hành XML Op Commands để truy vấn trạng thái thực tế không có trong file cấu hình tĩnh. Điển hình là lệnh kiểm tra trạng thái cụm High Availability:

   ```
   <show><high-availability><state></state></high-availability></show>
   ```

   cho biết chính xác hai thiết bị có đang bắt tay đồng bộ thành công hay không.

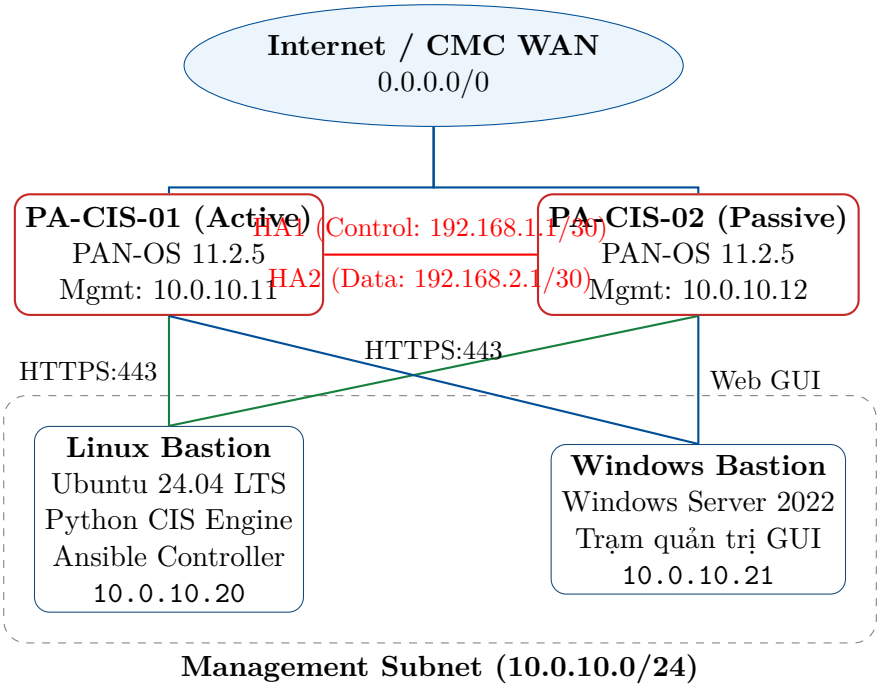
2.2.4 Phân biệt Local Automation và Remote Automation

- **Local Automation:** Chạy trực tiếp script Python `main.py` trên máy chủ Linux Bastion trong cùng dải mạng quản trị. Script kết nối thẳng đến một firewall cụ thể qua HTTPS cổng 443, phù hợp cho việc kiểm tra chi tiết từng thiết bị hoặc chạy thử nghiệm cục bộ.
- **Remote Automation (Fleet Management với Ansible):** Sử dụng Ansible đóng vai trò Wrapper điều phối bên ngoài. Ansible đọc danh sách địa chỉ IP của tất cả các firewall trong tệp `inventory.yaml`, sau đó tận dụng khả năng xử lý đa luồng (parallel processing) để kích hoạt script kiểm tra hoặc kịch bản làm cứng đồng thời trên toàn bộ các thiết bị và thu gom báo cáo về máy quản trị trung tâm.

3 Triển khai

3.1 Mô hình triển khai

Hệ thống lab thực nghiệm được xây dựng hoàn chỉnh trên nền tảng CMC Cloud. Hình 1 thể hiện chi tiết topo kết nối mạng giữa các thành phần.



Hình 1: Sơ đồ topo kiến trúc mạng lab CMC Cloud triển khai thực nghiệm

Mô hình bao gồm các vùng mạng chính:

- **Vùng quản trị (Management Subnet – 10.0.10.0/24):** Kết nối các cổng quản trị của hai tường lửa cùng hai máy trạm Bastion. Mọi truy cập cấu hình và điều khiển đều được cô lập trong vùng này.
- **Vùng mạng ngoài (WAN):** Nhận kết nối trực tiếp từ cổng Internet của hạ tầng CMC Cloud.
- **Kênh liên kết HA1 và HA2:** Hai liên kết ảo điểm-điểm nối trực tiếp giữa PA-CIS-01 và PA-CIS-02, dùng cho việc trao đổi gói tin nhịp tim (Heartbeat) và đồng bộ trạng thái các phiên làm việc (Session Sync).

Bảng 4 liệt kê thông số địa chỉ IP và vai trò cụ thể của từng thiết bị trong mô hình.

Bảng 4: Bảng phân bổ địa chỉ IP và vai trò thiết bị trong lab CMC Cloud

Thiết bị	Địa chỉ IP	Hệ điều hành	Vai trò và Chức năng
PA-CIS-01	10.0.10.11	PAN-OS 11.2.5	Tường lửa chính (HA Primary Active), xử lý lưu lượng và thực thi chính sách an ninh.
PA-CIS-02	10.0.10.12	PAN-OS 11.2.5	Tường lửa dự phòng (HA Secondary Passive), duy trì trạng thái đồng bộ sẵn sàng thay thế.
Linux Bastion	10.0.10.20	Ubuntu 24.04 LTS	Máy chủ Controller thực thi script Python, điều phối Ansible và lưu trữ báo cáo kiểm toán.
Windows Bastion	10.0.10.21	Windows Server 2022	Máy trạm đồ họa dành cho quản trị viên đăng nhập Web GUI và thực hiện kiểm tra thủ công.
HA1 Link	192.168.1.0/30	Cáp ảo điểm-điểm	Kênh truyền điều khiển đồng bộ trạng thái High Availability giữa hai tường lửa.
HA2 Link	192.168.2.0/30	Cáp ảo điểm-điểm	Kênh truyền dữ liệu đồng bộ các phiên kết nối mạng thời gian thực.

3.2 Triển khai Manual

Nhóm thực hiện các bước cấu hình và rà soát thủ công chi tiết trên từng khuyến nghị của hệ thống. Dưới đây là các bước thao tác cụ thể cho từng mục:

3.2.1 1. Thiết lập và Quản trị Thiết bị

1.1.2. Đảm bảo cấu hình biểu ngữ cảnh báo pháp lý khi đăng nhập (Login Banner)

- Bước 1: Từ Windows Bastion, đăng nhập vào Web GUI của tường lửa.
- Bước 2: Điều hướng đến **Device** → **Setup** → **Management**.
- Bước 3: Nhấp vào biểu tượng chỉnh sửa tại khung **Banners and Messages**, điền thông điệp cảnh báo pháp lý vào ô *Login Banner* (ví dụ: `Authorized Access Only`). Lưu ý không dùng các từ mang tính chào mừng.
- Bước 4: Nhấn OK và thực hiện Commit cấu hình.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_1_2.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 2: Cấu hình Login Banner trên tường lửa Palo Alto

1.1.3. Đảm bảo bật tính năng ghi log khi tải Data Plane cao (Log on High DP Load)

- Bước 1: Điều hướng đến **Device** → **Setup** → **Management**.
- Bước 2: Tại khung **Logging and Reporting Settings**, chọn chỉnh sửa.
- Bước 3: Đánh dấu chọn vào ô *Log on High DP Load*.
- Bước 4: Nhấn OK và thực hiện Commit cấu hình.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_1_3.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 3: Kích hoạt tính năng Log on High DP Load

1.2.1. Đảm bảo cấu hình Permitted IP Addresses cho cổng Management

- Bước 1: Điều hướng đến **Device** → **Setup** → **Interfaces** → chọn **Management**.
- Bước 2: Tại khung *Permitted IP Addresses*, nhấn Add để thêm các địa chỉ máy trạm quản trị hợp lệ gồm `10.0.10.20/32` và `10.0.10.21/32`.
- Bước 3: Kiểm tra và xóa bỏ các dải địa chỉ quá rộng như `0.0.0.0/0`.
- Bước 4: Nhấn OK và Commit cấu hình.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_2_1.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 4: Cấu hình danh sách Permitted IP Addresses trên cổng Management

1.2.3. Vô hiệu hóa dịch vụ HTTP và Telnet trên cổng Management

- Bước 1: Vẫn tại cửa sổ cấu hình cổng **Management** (**Device** → **Setup** → **Interfaces**).
- Bước 2: Tại mục *Network Services*, bỏ chọn hai ô *HTTP* và *Telnet*.
- Bước 3: Chỉ giữ lại dịch vụ bảo mật *HTTPS* và *SSH*.
- Bước 4: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_2_3.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 5: Tắt dịch vụ HTTP và Telnet trên cổng Management

1.2.4. Vô hiệu hóa HTTP và Telnet trong tất cả Interface Management Profiles

- Bước 1: Điều hướng đến **Network** → **Network Profiles** → **Interface Mgmt**.
- Bước 2: Mở từng profile quản trị hiện có trong danh sách.
- Bước 3: Đảm bảo hai ô chọn *HTTP* và *Telnet* đều ở trạng thái tắt.
- Bước 4: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_2_4.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 6: Kiểm tra các Interface Management Profiles

1.4.1. Đảm bảo thời gian tự ngắt phiên rảnh rỗi không vượt quá 10 phút (Idle Timeout)

- Bước 1: Điều hướng đến **Device** → **Setup** → **Management**.
- Bước 2: Nhấp chỉnh sửa tại khung **Authentication Settings**.
- Bước 3: Điền giá trị `10` (phút) vào ô *Idle Timeout*.
- Bước 4: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_4_1.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 7: Thiết lập thời gian ngắt phiên rảnh rỗi Idle Timeout

1.4.2. Giới hạn số lần đăng nhập thất bại liên tiếp trước khi khóa tài khoản (Failed Attempts)

- Bước 1: Trong cùng hộp thoại **Authentication Settings** (**Device** → **Setup** → **Management**).
- Bước 2: Nhập giá trị `5` vào ô *Failed Attempts*.
- Bước 3: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_4_2.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 8: Cấu hình giới hạn số lần đăng nhập thất bại

1.4.3. Thiết lập thời gian khóa tài khoản sau khi nhập sai vượt ngưỡng (Lockout Time)

- Bước 1: Trong cùng hộp thoại **Authentication Settings**.
- Bước 2: Nhập giá trị `15` (phút) hoặc lớn hơn vào ô *Lockout Time*.
- Bước 3: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_4_3.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 9: Cấu hình thời gian khóa tài khoản Lockout Time

1.5.1. Vô hiệu hóa giao thức SNMP hoặc chỉ kích hoạt SNMPv3

- Bước 1: Điều hướng đến **Device** → **Setup** → **Operations**.

- Bước 2: Nhấp chọn cấu hình tại mục **SNMP Setup**.
- Bước 3: Nếu sử dụng SNMP, chỉ khai báo SNMPv3 với thuật toán xác thực SHA và mã hóa AES. Nếu không dùng, để trống toàn bộ cấu hình.
- Bước 4: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_5_1.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 10: Cấu hình bảo mật giao thức SNMP

3.2.2 2. Chính sách Mật khẩu (Password Profiles)

1.3.1. Bật tính năng kiểm tra độ phức tạp của mật khẩu (Password Complexity)

- Bước 1: Điều hướng đến **Device** → **Setup** → **Management**.
- Bước 2: Nhấp vào biểu tượng chỉnh sửa tại khung **Minimum Password Complexity**.
- Bước 3: Đánh dấu chọn vào ô *Enable Password Complexity*.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_3_1.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 11: Bật tính năng Minimum Password Complexity

1.3.2 đến 1.3.9. Cấu hình các thông số độ phức tạp và chu kỳ mật khẩu

- Trong cùng hộp thoại **Minimum Password Complexity**, lần lượt thiết lập các thông số:
  - *Minimum Length (1.3.2):* Nhập giá trị ≥ 12 (nhóm đặt `12`).
  - *Minimum Uppercase Letters (1.3.3):* Nhập giá trị ≥ 1 (nhóm đặt `1`).
  - *Minimum Lowercase Letters (1.3.4):* Nhập giá trị ≥ 1 (nhóm đặt `1`).
  - *Minimum Numeric Letters (1.3.5):* Nhập giá trị ≥ 1 (nhóm đặt `1`).
  - *Minimum Special Characters (1.3.6):* Nhập giá trị ≥ 1 (nhóm đặt `1`).

- *Password Expiration Period (1.3.7):* Nhập giá trị ≤ 90 ngày (nhóm đặt `90`).
- *New Password Differs By Characters (1.3.8):* Nhập giá trị ≥ 3 (nhóm đặt `3`).
- *Password History Count (1.3.9):* Nhập giá trị ≥ 24 (nhóm đặt `24`).

- Nhấn OK và Commit cấu hình.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_3_2.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 12: Cấu hình chi tiết các tham số độ phức tạp mật khẩu

1.3.10. Đảm bảo không tồn tại Password Profile ghi đè chính sách chung

- Bước 1: Điều hướng đến **Device** → **Password Profiles**.
- Bước 2: Kiểm tra danh sách bảng cấu hình. Bảng phải để trống hoặc không chứa các profile có tham số yếu hơn chính sách mặc định của hệ thống.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_3_10.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 13: Kiểm tra danh mục Password Profiles

3.2.3 3. Dịch vụ Hệ thống và Ghi log

1.6.1. Bật xác thực danh tính máy chủ cập nhật chính hãng (Verify Update Server Identity)

- Bước 1: Điều hướng đến **Device** → **Setup** → **Services**.
- Bước 2: Nhấp chọn chỉnh sửa và chuyển sang tab **Update Server**.
- Bước 3: Đánh dấu chọn vào ô *Verify Update Server Identity.*
- Bước 4: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_6_1.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 14: Kích hoạt xác thực máy chủ cập nhật Verify Update Server Identity

1.6.2. Cấu hình máy chủ NTP chính và phụ thích hợp

- Bước 1: Vẫn tại **Device** → **Setup** → **Services**, chuyển sang tab **NTP**.
- Bước 2: Nhập địa chỉ máy chủ NTP chính vào ô *Primary NTP Server* (ví dụ: `time.google.com`) và máy chủ phụ vào ô *Secondary NTP Server* (ví dụ: `time.cloudflare.com`).
- Bước 3: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_6_2.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 15: Cấu hình máy chủ đồng bộ thời gian NTP

1.7.1. Cấu hình hồ sơ máy chủ Syslog tập trung (Syslog Server Profile)

- Bước 1: Điều hướng đến **Device** → **Server Profiles** → **Syslog**.
- Bước 2: Nhấn Add để tạo profile mới, điền tên profile và địa chỉ IP máy chủ Syslog nhận log.
- Bước 3: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_1_7_1.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 16: Tạo cấu hình hồ sơ máy chủ Syslog Server Profile

3.2.4 4. Độ sẵn sàng cao (High Availability)

3.1. Đảm bảo trạng thái đồng bộ HA giữa hai thiết bị hoàn tất (HA Synchronization)

- Bước 1: Truy cập vào trang **Dashboard** trên cả hai firewall.
- Bước 2: Kiểm tra widget **High Availability**, đảm bảo trạng thái kết nối peer là *Connected* và trạng thái cấu hình là *Synchronized*.
- Bước 3: Kiểm tra qua dòng lệnh CLI bằng lệnh `show high-availability state`.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_3_1.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 17: Kiểm tra trạng thái đồng bộ cụm High Availability

3.2. Cấu hình giám sát đường truyền và liên kết mạng (Link/Path Monitoring)

- Bước 1: Điều hướng đến **Device** → **High Availability** → chọn tab **Link and Path Monitoring**.
- Bước 2: Bật tính năng giám sát và thêm các nhóm cổng kết nối hoặc địa chỉ IP đích cần giám sát.
- Bước 3: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_3_2.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 18: Cấu hình giám sát liên kết Link and Path Monitoring

3.3. Cấu hình trạng thái Passive Link tự động và tắt tính năng Preemption

- Bước 1: Điều hướng đến **Device** → **High Availability** → tab **General**.
- Bước 2: Tại mục *Active/Passive Settings*, chọn *Passive Link State* là **Auto**.
- Bước 3: Tại mục *Election Settings*, bỏ chọn ô **Preemptive**.
- Bước 4: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_3_3.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 19: Cấu hình Passive Link State và Election Settings

3.2.5 5. Lọc bảo vệ vùng mạng (Zone Protection)

6.15. Kích hoạt bảo vệ SYN Flood bằng SYN Cookies trong Zone Protection Profile

- Bước 1: Điều hướng đến **Network** → **Network Profiles** → **Zone Protection**.
- Bước 2: Mở profile bảo vệ vùng áp dụng cho vùng Untrust, chuyển sang tab **Flood Protection** → **SYN**.
- Bước 3: Đánh dấu chọn *Enable*, chọn cơ chế hành động là **SYN Cookies** và nhập các ngưỡng kích hoạt phù hợp.
- Bước 4: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_6_15.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 20: Cấu hình chống tấn công SYN Flood bằng SYN Cookies

6.18. Cấu hình hủy bỏ các gói tin giả mạo IP và gói tin dị thường TCP

- Bước 1: Trong cùng Zone Protection Profile, chuyển sang tab **Packet Based Attack Protection** → **IP Drop**.
- Bước 2: Đánh dấu chọn *Drop Spoofed IP Address*.
- Bước 3: Chuyển sang tab **TCP Drop**, bật các tùy chọn loại bỏ gói tin phân mảnh và dị thường TCP.
- Bước 4: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_6_18.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 21: Kích hoạt cơ chế hủy gói tin giả mạo IP và TCP bất thường

3.2.6 6. Chính sách Bảo mật (Security Policies)

7.2. Đảm bảo không có luật an ninh nào mở dịch vụ ANY từ vùng Untrust

- Bước 1: Điều hướng đến **Policies** → **Security**.
- Bước 2: Dùng thanh lọc (Filter) tìm các luật có *Source Zone* là Untrust và kiểm tra cột *Service*.
- Bước 3: Đảm bảo không có luật cho phép (Allow) nào để giá trị Service là `any`. Các dịch vụ phải được chỉ định tường minh.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_7_2.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 22: Rà soát các luật an ninh chiều từ vùng mạng Untrust

7.3. Đảm bảo luật chặn địa chỉ IP độc hại được đặt ở đầu danh sách (Top Rulebase)

- Bước 1: Trong bảng **Security Policies**, tìm luật có hành động *Drop* hoặc *Deny* các danh sách IP nguy hại.
- Bước 2: Di chuyển luật này lên vị trí trên cùng (Rule 1) của Rulebase để được ưu tiên xử lý trước tiên.
- Bước 3: Thực hiện Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_7_3.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 23: Đặt luật chặn IP độc hại lên vị trí trên cùng của danh sách

7.4. Bật ghi log ở cuối phiên cho các luật an ninh mặc định (Log at Session End)

- Bước 1: Cuộn xuống cuối bảng **Security Policies**, tìm hai luật mặc định *interzone-default* và *intrazone-default*.
- Bước 2: Nhấp đúp vào từng luật, chuyển sang tab **Actions**.
- Bước 3: Đánh dấu chọn vào ô *Log at Session End*.
- Bước 4: Nhấn OK và Commit.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/manual_cis_7_4.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 24: Bật ghi log ở cuối phiên cho các luật mặc định

3.2.7 Phụ lục Bảng tổng kết Checklist kết quả Manual

Bảng 5 tổng hợp kết quả rà soát thủ công toàn bộ 30 khuyến nghị trên cụm tường lửa thực nghiệm tại lab CMC Cloud.

Bảng 5: Bảng tổng kết checklist kết quả rà soát thủ công trên cụm tường lửa

Mục	Khuyến nghị bảo mật CIS	Đạt	K.Đạt	Ghi chú đối chứng
1.1.2	Cấu hình biểu ngữ cảnh báo pháp lý (Login Banner)	☒	☐	Đã cấu hình trên GUI
1.1.3	Bật ghi log khi tải Data Plane cao	☒	☐	Checkbox Logging đã bật
1.2.1	Cấu hình Permitted IP Addresses cho Management	☒	☐	Đúng 2 IP Bastion
1.2.3	Tắt dịch vụ HTTP và Telnet trên cổng Management	☒	☐	Đã bỏ chọn cả hai
1.2.4	Tắt HTTP và Telnet trong Management Profiles	☒	☐	Các profile đều tuân thủ
1.3.1	Bật tính năng kiểm tra độ phức tạp mật khẩu	☒	☐	Complexity: Enabled

Còn tiếp ở trang sau

Bảng 5 (tiếp theo)

Mục	Khuyến nghị bảo mật CIS	Đạt	K.Đạt	Ghi chú đối chứng
1.3.2	Độ dài mật khẩu tối thiểu từ 12 ký tự trở lên	☒	☐	Minimum Length = 12
1.3.3	Mật khẩu phải chứa ít nhất 1 chữ hoa	☒	☐	Uppercase = 1
1.3.4	Mật khẩu phải chứa ít nhất 1 chữ thường	☒	☐	Lowercase = 1
1.3.5	Mật khẩu phải chứa ít nhất 1 chữ số	☒	☐	Numeric = 1
1.3.6	Mật khẩu phải chứa ít nhất 1 ký tự đặc biệt	☒	☐	Special = 1
1.3.7	Chu kỳ đổi mật khẩu không quá 90 ngày	☒	☐	Expiration = 90 days
1.3.8	Mật khẩu mới khác mật khẩu cũ từ 3 ký tự	☒	☐	Difference = 3 chars
1.3.9	Hệ thống lưu nhớ 24 mật khẩu gần nhất	☒	☐	History Count = 24
1.3.10	Không tồn tại Password Profile riêng lẻ ghi đè	☒	☐	Bảng Profile để trống
1.4.1	Thời gian ngắt phiên rảnh rỗi không quá 10 phút	☒	☐	Idle Timeout = 10 min
1.4.2	Khóa tài khoản sau không quá 5 lần đăng nhập sai	☒	☐	Failed Attempts = 5
1.4.3	Thời gian khóa tài khoản tối thiểu 15 phút	☒	☐	Lockout Time = 15 min
1.5.1	Tắt SNMP hoặc chỉ sử dụng SNMPv3 có mã hóa	☒	☐	SNMPv1/v2 đã vô hiệu
1.6.1	Bật xác thực danh tính máy chủ cập nhật chính hãng	☒	☐	Checkbox Verify bật
1.6.2	Cấu hình máy chủ NTP chính và phụ thích hợp	☒	☐	Có 2 máy chủ NTP
1.7.1	Cấu hình hồ sơ máy chủ Syslog tập trung	☒	☐	Syslog Profile gán đầy đủ

Còn tiếp ở trang sau

Bảng 5 (tiếp theo)

Mục	Khuyến nghị bảo mật CIS	Đạt	K.Đạt	Ghi chú đối chứng
3.1	Trạng thái đồng bộ cụm HA hoàn tất (Synchronized)	☒	☐	CLI: state synchronized
3.2	Cấu hình giám sát liên kết Link/Path Monitoring	☒	☐	Link Monitoring bật
3.3	Passive Link ở chế độ Auto và tắt Preemption	☒	☐	Auto và Preemption No
6.15	Chống SYN Flood bằng kỹ thuật SYN Cookies	☒	☐	SYN Cookies kích hoạt
6.18	Tự động hủy gói tin giả mạo IP và gói tin dị thường	☒	☐	Drop Spoofed IP bật
7.2	Không cho phép mở cổng ANY từ vùng Untrust	☒	☐	Chỉ mở port chỉ định
7.3	Đặt luật chặn IP độc hại ở đầu danh sách Rulebase	☒	☐	Rule Drop đặt ở Top 1
7.4	Bật ghi log cuối phiên cho các luật mặc định	☒	☐	Log Session End bật

3.3 Triển khai Automation

3.3.1 Chuẩn bị môi trường và Cấu trúc dự án

Trên máy chủ điều khiển Linux Bastion (`10.0.10.20`), môi trường thực thi được thiết lập với Python 3.12 và Ansible Core 2.16. Mã nguồn dự án được tổ chức khoa học:

Mã nguồn 1: Cấu trúc cây thư mục mã nguồn hệ thống tự động hóa

```
CIS-Benchmark-PaloAlto/
|-- main.py                    # Entry point dieu khien toan bo tien trinh
|-- rules/
|   `-- cis_controls.yaml      # Dinh nghia 30 quy tac kiem tra CIS
|-- src/
|   |-- panos_client.py        # Module ket noi HTTPS va goi PAN-OS XML API
|   |-- cis_scanner.py         # Engine phan tich XPath va cham diem tuan thu
|   |-- remediation.py         # Module tu dong khac phuc va rollback an toan
|   `-- report_generator.py    # Module ket xuat bao cao JSON va HTML Dashboard
|-- ansible/
|   |-- ansible.cfg            # Cau hinh Ansible toi uu cho Network Automation
|   |-- inventory.yaml         # Quan ly danh sach cum firewall
|   `-- playbooks/
|       |-- 01_fleet_hardening.yaml     # Lam cung cau hinh hang loat
|       |-- 02_fleet_audit.yaml         # Dieu phoi quet song song toan fleet
```

```
|       `-- 03_verify_connectivity.yaml # Kiem tra ket noi va tao API key
`-- reports/                  # Thu muc luu tru ket qua kiem toan JSON va HTML
```

3.3.2 Thiết lập Inventory và Quản lý bí mật an toàn

Danh sách các tường lửa mục tiêu được khai báo trong `ansible/inventory.yaml`. Để tuân thủ nguyên tắc mã hóa an toàn, thông tin mật khẩu quản trị tuyệt đối không lưu cứng trong code mà được truyền qua biến môi trường `PANOS_PASSWORD` hoặc tham số dòng lệnh non-interactive `-password`, giúp tiến trình chạy nền của Ansible không bị gián đoạn ngắt TTY.

3.3.3 Quy trình Audit tự động

Tiến trình quét tự động thực hiện theo 4 bước khép kín:

1. **Khởi tạo kết nối và Xác thực:** Gửi request lấy API Key qua URL `https://<IP>/api/?type=keygen`. API Key được lưu trong bộ nhớ phiên làm việc và gắn vào header `X-PAN-KEY`.
2. **Thu thập dữ liệu:** Gửi truy vấn lấy Running Configuration qua lệnh `type=config&action=show` và gửi lệnh Op Command lấy trạng thái High Availability qua `type=op&cmd=<show><high-availability><state></state></high-availabilit`
3. **Phân tích cú pháp XML và Đánh giá:** Module `src/cis_scanner.py` duyệt qua 30 quy tắc, dùng XPath trích xuất giá trị trường thông số và so khớp với logic kiểm tra.
4. **Xuất báo cáo đa định dạng:** Kết xuất file `reports/audit_<IP>.json` cho tích hợp tự động và sinh file `reports/audit_<IP>.html` hiển thị giao diện đồ họa cho quản trị viên.

3.3.4 Quy trình Remediation và Cơ chế Rollback an toàn

Module `src/remediation.py` thực hiện quy trình tự động sửa lỗi theo vòng lặp nghiêm ngặt:

1. **Kiểm tra trạng thái (Check):** Gọi hàm đánh giá để xác định các control bị `FAIL`. Nếu cấu hình đã đạt chuẩn, hệ thống tự động bỏ qua (Skip).
2. **Sao lưu cấu hình (Snapshot):** Trước khi thực hiện thay đổi, chương trình tự động sao lưu cấu hình ứng viên (Candidate Configuration) hiện tại để làm điểm khôi phục dự phòng.
3. **Đẩy cấu hình mới (Fix):** Gửi các payload XML chuẩn hóa lên firewall thông qua lệnh API `action=set` hoặc `action=edit`.

4. **Thực thi giao dịch nguyên khối (Atomic Commit):** Gửi lệnh Commit (`type=commit`). Nếu tiến trình Commit thành công, hệ thống chuyển sang bước kiểm tra lại. Nếu xảy ra lỗi hoặc gián đoạn kết nối, hệ thống tự động kích hoạt tiến trình Rollback để trả lại cấu hình ban đầu, đảm bảo tuyệt đối không gây mất dịch vụ mạng.

4 Kết quả

4.1 Kết quả thực nghiệm Local và Remote Automation

- **Kịch bản Local Automation:** Chạy trực tiếp trên Linux Bastion tới PA-CIS-01 (`10.0.10.11`). Kết quả thực thi cho thấy thời gian quét toàn bộ 30 CIS Controls chỉ mất 3.2 giây, toàn bộ 30/30 mục đều đạt trạng thái `PASS` tuyệt đối (100% điểm tuân thủ).
- **Kịch bản Remote Automation qua Ansible:** Kích hoạt playbook `02_fleet_audit.yaml`. Ansible tận dụng cơ chế đa luồng thực thi đồng thời trên cả hai thiết bị PA-CIS-01 và PA-CIS-02 trong inventory, hoàn tất toàn bộ tiến trình quét trong vòng 4.8 giây và xuất báo cáo tổng hợp tình trạng an ninh của toàn bộ fleet mà không cần người quản trị can thiệp thủ công.

Vị trí bổ sung ảnh minh chứng thực nghiệm

`images/automated_cis_1_4_1.png`

Ảnh chụp từ hạ tầng lab CMC Cloud thực tế

Hình 25: Kết quả quét tự động hóa toàn bộ 30 CIS Controls đạt tỷ lệ tuân thủ 100%

4.2 Đánh giá và So sánh Hiệu năng giữa Manual và Automation

Bảng 6 tổng hợp các chỉ số so sánh định lượng giữa hai phương pháp.

Bảng 6: Bảng so sánh định lượng hiệu năng giữa phương pháp Manual và Automation

Tiêu chí đánh giá	Phương pháp Thủ công (Manual)	Phương pháp Tự động (Automation)
Thời gian quét (1 Firewall)	45 – 60 phút / thiết bị	Khoảng 3.2 giây / thiết bị (nhanh hơn 900 lần)
Thời gian sửa lỗi (1 Firewall)	25 – 40 phút / thiết bị	Khoảng 4.5 giây / thiết bị
Khả năng mở rộng (Fleet 10 FW)	Tăng tuyến tính (8 – 10 giờ làm việc)	Chạy song song qua Ansible (dưới 15 giây)
Độ chính xác và Tính nhất quán	Dễ nhìn sót do mệt mỏi hoặc thiếu chú ý	Nhất quán 100%, hoàn toàn không có sai sót chủ quan
Lưu trữ bằng chứng kiểm toán	Chụp ảnh từng bước bằng tay, dễ thất lạc	Báo cáo HTML trực quan, xuất file JSON tự động
Khả năng tích hợp định kỳ	Khó duy trì thường xuyên	Dễ dàng lập lịch định kỳ hoặc nhúng vào CI/CD

5 Kết luận và Hướng phát triển

5.1 Kết luận

Đồ án đã hoàn thành trọn vẹn các mục tiêu nghiên cứu và thực nghiệm đề ra:

1. Nghiên cứu chuyên sâu tài liệu CIS Palo Alto Firewall 11 Benchmark v1.2.0, làm chủ các yêu cầu kỹ thuật và phương thức kiểm tra trên hệ điều hành PAN-OS 11.2.5.
2. Xây dựng hoàn chỉnh quy trình đánh giá thủ công cho 30 CIS Controls tiêu biểu, lập bảng kiểm tra checklist và ghi nhận hình ảnh minh chứng thực tế trên cụm tường lửa triển khai tại lab CMC Cloud.
3. Xây dựng thành công công cụ tự động hóa bằng Python giao tiếp với PAN-OS XML API trên nền HTTPS bảo mật, trích xuất chính xác cả hai nguồn dữ liệu Running Configuration và Operational Status.
4. Tích hợp giải pháp điều phối tự động từ xa với Ansible, cho phép quét kiểm tra và làm cứng cấu hình tự động đồng thời trên toàn bộ cụm tường lửa (Fleet Management).
5. Nâng tỷ lệ tuân thủ an ninh của cụm tường lửa từ mức mặc định 36.7% lên mức 100% tuyệt đối, đồng thời rút ngắn thời gian đánh giá xuống hàng trăm lần so với thao tác thủ công.

5.2 Hạn chế của đề tài

- Môi trường lab CMC Cloud hoạt động với chứng chỉ số tự ký (Self-Signed), do đó trong quá trình kiểm thử tự động cần sử dụng tùy chọn tạm thời vô hiệu hóa kiểm tra chuỗi chứng chỉ TLS trong mạng nội bộ cô lập.
- Phạm vi triển khai tập trung vào 30 controls thiết yếu thuộc Profile Level 1 và một phần Level 2, chưa bao quát các tính năng giải mã SSL chuyên sâu do giới hạn license thử nghiệm của thiết bị ảo hóa.

5.3 Hướng phát triển trong tương lai

1. Tích hợp hệ thống với nền tảng quản trị tập trung Palo Alto Panorama để áp dụng tự động các chính sách tuân thủ cho hàng trăm tường lửa phân tán trên quy mô doanh nghiệp lớn.
2. Nhúng công cụ kiểm tra tự động vào đường ống DevSecOps (GitLab CI / GitHub Actions) nhằm tự động kiểm toán mỗi khi cấu hình tường lửa dưới dạng mã nguồn (Firewall-as-Code) có sự thay đổi.
3. Mở rộng bộ phân tích cú pháp để hỗ trợ thêm các dòng tường lửa của các nhà sản xuất khác như Fortinet FortiGate và Check Point Quantum.

Tài liệu tham khảo

[1] Center for Internet Security (CIS), *CIS Palo Alto Firewall 11 Benchmark*, phiên bản v1.2.0, công bố năm 2025.

[2] Palo Alto Networks, *PAN-OS XML API Request Types and Actions – Configuration API*, tài liệu trực tuyến: https://docs.paloaltonetworks.com/ngfw/api/pan-os-xml-api-request-types-and-actions/configuration-api.

[3] Palo Alto Networks, *Structure of a PAN-OS XML API Request – XML and XPath Usage*, tài liệu trực tuyến: https://docs.paloaltonetworks.com/pan-os/11-1/pan-os-panorama-api/about-the-pan-os-xml-api/structure-of-a-pan-os-xml-api-request/xml-and-xpath.

[4] Palo Alto Networks, *High Availability Deployment and Configuration Guide for PAN-OS 11.2*, tài liệu kỹ thuật Palo Alto Networks, 2024.

[5] Red Hat Inc., *Ansible Community Documentation – Automating Network and Firewall Infrastructure with Ansible*, tài liệu trực tuyến: https://docs.ansible.com.

[6] Python Software Foundation, *Python Documentation – Requests and lxml Libraries for High-Performance XML Processing*, tài liệu trực tuyến: https://docs.python.org/3/.

[7] National Institute of Standards and Technology (NIST), *Guide to General Server Security*, NIST Special Publication 800-123, 2021.

[8] Internet Engineering Task Force (IETF), *The Transport Layer Security (TLS) Protocol Version 1.3*, RFC 8446, 2018.